COLORADO
Information Security
Governor's Office of Information Technology

TS-CISO-001: Authentication & Account Management Standard

Document ID	TS-CISO-001
Title	Authentication & Account Management Standard v. 2026
Executive Sponsor	Jill Fraser, Chief Information Security Officer
Issuing Authority	Governor's Office of Information Technology (OIT)
Applies to	All state government agencies, employees, contractors, vendors, and external users who access state government information systems and applications, regardless of location or device, including all applications, hosting environments, and physical and connected technologies.
Instrument Type	Standard
Version	4.0
Effective Date	02/01/2026
Last Updated	05/14/2026

Purpose

This standard defines security requirements for secure access and account management across all state information systems and applications, including on-premises and cloud environments. It supports compliance with the Colorado Information Security Policies (CISPs).

Scope

This standard applies to all state government agencies, employees, contractors, vendors, and external users who access state government information systems and applications, regardless of location or device. This includes all applications and hosting environments, and access to physical and connected technologies.

The appropriate authentication and account management standard security requirements are listed below. Additional requirements must be implemented based on the regulated data type(s).

Requirements

User Account Lifecycle Management

A standard operating procedure must be in place for all phases of a user account's existence: creation, modification, disablement, and deletion. Accounts inactive for 90 days must be routinely identified, monitored, and appropriately managed.

Account Types

The standard recognizes two main types of accounts (basic and advanced):

- Basic User Accounts: Standard accounts used for accessing State Information Systems and services, such as email, without administrative privileges.
- Advanced Accounts: Accounts with elevated or non-personal access used for administrative tasks, system-level functions, or automated service operations. This category includes Privileged User Accounts (e.g., administrator or root) and Service Accounts.

Password Management – Baseline Requirements

- Password Requirement: All accounts must be protected by a password. Password-less accounts are strictly prohibited.
- Password Expiration: All account passwords must expire in accordance with an established and approved password expiration policy or Standard Operating Procedure (SOP).
- Password Changes and Resets: Passwords must be changed immediately if compromise is suspected. In all other circumstances, password changes or resets may occur only upon request and after verification of identity and authorization.
- Secure Password Communication: Passwords and password reset credentials must be communicated using secure methods, including but not limited to in-person delivery, HTTPS-secured communication, or encrypted email.
- Password Confidentiality: Passwords must not be shared with, disclosed to, or accessible by anyone other than the authorized account owner or designated system process.
- Initial Password Provisioning: For newly created accounts where an initial password is required for provisioning or onboarding, the password must be communicated securely and must be changed upon first use.

Basic User Account Passwords

The Office of Information Technology (OIT) is responsible for the establishment and mandatory enforcement of minimum password complexity requirements. Agencies are provided with these as options; OIT default requires Standard Option 1. All Basic User Accounts must meet one of the two minimum standards below.

Standard	Length	Complexity	Expiration	Reminder
Standard Option 1 (Complex Password)	Minimum ten (10) characters.	Must contain at least one (1) character from each category: uppercase letters, lowercase letters, numeric digits, non-alphanumeric characters (symbols/punctuation).	Every ninety (90) days or when a compromise is suspected.	Users receive a reminder fourteen (14) days prior to expiration.
Standard Option 2 (Long Password) — note: some regulatory compliances do not currently allow Option 2	Minimum twenty-four (24) characters.	No additional complexity requirements beyond length (no mandatory uppercase, lowercase, numeric, or symbols).	Every three hundred sixty-five (365) days or when a compromise is suspected.	Users receive a reminder fourteen (14) days prior to expiration.

New Users: For onboarding of new employees, where a hiring authority may receive a temporary password, the password must be shared securely with the new employee. The new employee must create a new password right away upon first login.

Advanced Account Passwords – Elevated Privilege Account Passwords

Requirement	Detail
Length	Minimum sixteen (16) characters.
Complexity	Must contain at least one (1) character from each category: uppercase letters, lowercase letters, numeric digits, non-alphanumeric characters (symbols/punctuation).
MFA	Required for all accounts with elevated privileges and all remote access.
Expiration	Every ninety (90) days.
Reminder	Users receive a reminder fourteen (14) days prior to expiration.

Service Account Passwords

Starting March 1, 2026, all newly created service accounts will be required to meet the following:

Requirement	Detail
Length	Minimum twenty-four (24) characters.
Complexity	Must contain at least two (2) characters from each of the following categories: uppercase letters, lowercase letters, numeric digits, non-alphanumeric characters (symbols/punctuation).
Usage Restriction	No interactive logins.
Storage	Passwords must be securely stored in the designated password repository associated with the service.
Expiration	Every three hundred sixty-five (365) days or when a compromise is suspected.

All default vendor passwords must be reset prior to connecting to the network and are required to meet the requirements of elevated privilege passwords.

Multi-Factor Authentication (MFA) Requirements

- The MFA solution must be configured according to vendor best practice guidance.
- MFA is required for all accounts with elevated privileges and all remote access.
- If a hardware MFA device is used, the devices must be securely issued, replaced, revoked, and disposed of when needed.

Exceptions

All exceptions must be documented, justified, and approved by the State of Colorado's Chief Information Security Officer (CISO) or other designated authority. Compensating controls must be documented, implemented, and maintained.

Compliance

The Information Security Office will monitor and advise on compliance with this standard.

References

- Password & Account Compliance Requirements
- Guidance for Creating Secure Passwords
- Encryption Standard TS-CISO-006